

YILDIZ

SİBER TEHDİT İSTİHBARATI TAKIMI

C2 Hunting

Eray Atalay





İçindekiler

İçindekiler	1
Giriş	2
Altyapı Analizi	2
Shodan Üzerinden "Cobalt Strike Beacon" Ürün Filtresiyle Doğrudan Avcılık	3
TLS/SSL Sertifika Anomalilerini Yakalamak	4
Cobalt Strike Varsayılan Sertifika Avı	4
Güncel C2'lerde Seri Numarası Avı	5
JARM Fingerprinting ile Avcılık	6
Popüler C2 Framework'lerin Bilinen JARM Hash Değerleri	6
JARM ile Shodan Üzerinden Canlı Avcılık	6
HTTP Protokol ve Response Header Anomalileri	7
Boşluk Anomalisi	7
Yanıt Başlığı Hash Analizi	8
Boş 404 Sayfası ve Hash Avı	9
HTML Hash Analizi	10
JA3 ve JA3S Parmak İzi Entegrasyonu	11
JA3 İstemci Parmak İzi	11
JA3S Sunucu Parmak İzi	11
Tehdit Tespiti	12
ISP Odaklı Filtreleme	13
Watermark ID Analizi	14
Sızdırılmış ve Korsan Sürümlerin Takibi	14
Aktör ve Kampanya Eşleştirmeleri	14
Varsayılan SSH İstemci Parmak İzi Tespiti	15
ASN ve Subnet Ölçeğinde Aktif Tarama Teknikleri	16
Alt Ağ Analizi	16
Nmap Scriptleri ile Konfigürasyon Çekme	16
Varsayılan DNS Sunucusu Yanıtı	16
Sahte IP Yanıt Anomalisi (Bogus IP Response)	16
Ağ Seviyesinde Avcılık	16
Atlatma Taktikleri	17
Avcılar İçin Kritik OpSec ve Güvenlik Uyarıları	17
Kaynakça	18



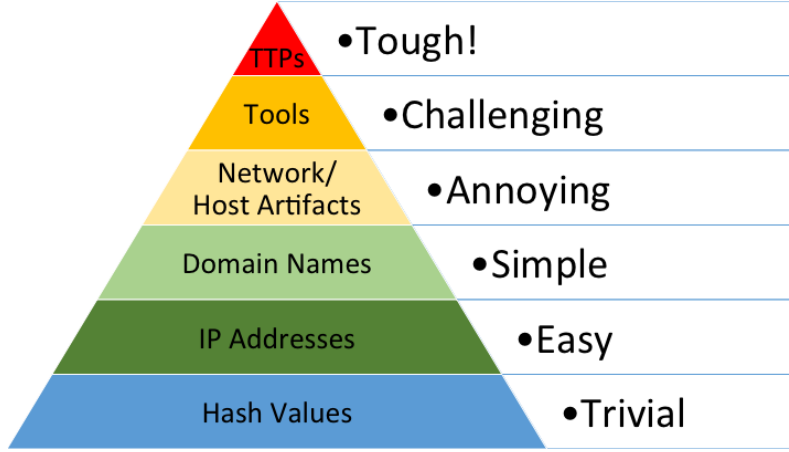
Giriş

Siber güvenlikte savunma reflekslerimiz genellikle reaktiftir. Bir alarmin düşmesini, EDR'in uyarı vermesini veya bir log satırının kırmızıya dönmesini bekleriz. Ancak gerçek bir Tehdit Avcısı, saldırganın kapıyı çalmasını beklemez. Saldırgan henüz operasyonuna başlamadan, internete açtığı komuta kontrol (C2 - Command and Control) sunucusunu kendi evinde, yani altyapısında yakalamayı hedefler.

Bu teknik rehberde, siber suçluların ve APT gruplarının arkalarında bıraktıkları dijital parmak izlerini kullanarak, Shodan ve JARM yardımıyla internetteki aktif C2 sunucularını (Cobalt Strike, Havoc, Sliver vb.) nasıl nokta atışı tespit edebileceğimizi uygulamalı olarak inceleyeceğiz.

Altyapı Analizi

David Bianco'nun Pyramid of Pain (Acı Piramidi) modeline göre. Piramidin en altında yer alan Hash değerlerini veya IP adreslerini engellemek saldırgana acı çekertmez, çünkü bunları saniyeler içinde değiştirebilir. Ancak piramidin üst basamaklarında yer alan Altyapı (Infrastructure) ve Araçlar (Tools) katmanına müdahale ettiğimizde, saldırganın tüm operasyonel düzenini bozmuş oluruz.



Görsel 1: Acı Piramidi

Saldırganlar C2 sunucularını kurarken genellikle otomatik scriptler kullanırlar veya varsayılan konfigürasyonları değiştirmeyi unuturlar. İşte bu dikkatsizlikler HTTP yanıt başlıklarında, TLS sertifikalarında veya ağ protokol davranışlarında anomalilere yol açar. Bizim işimiz bu anomalileri avlamaktır.

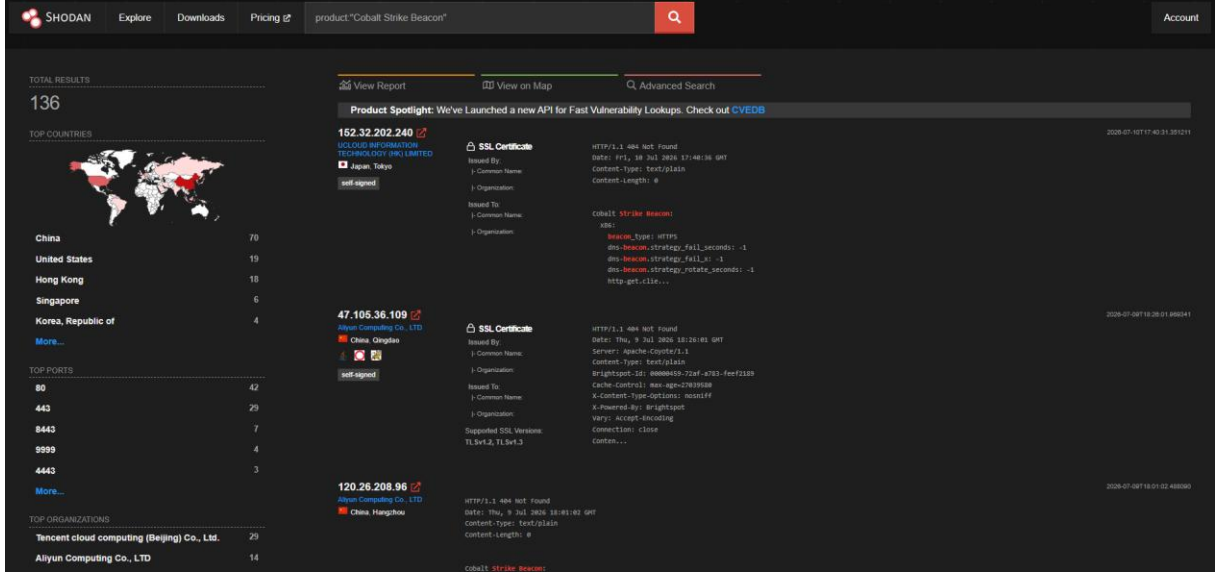


Shodan Üzerinden "Cobalt Strike Beacon" Ürün Filtresiyle Doğrudan Avcılık

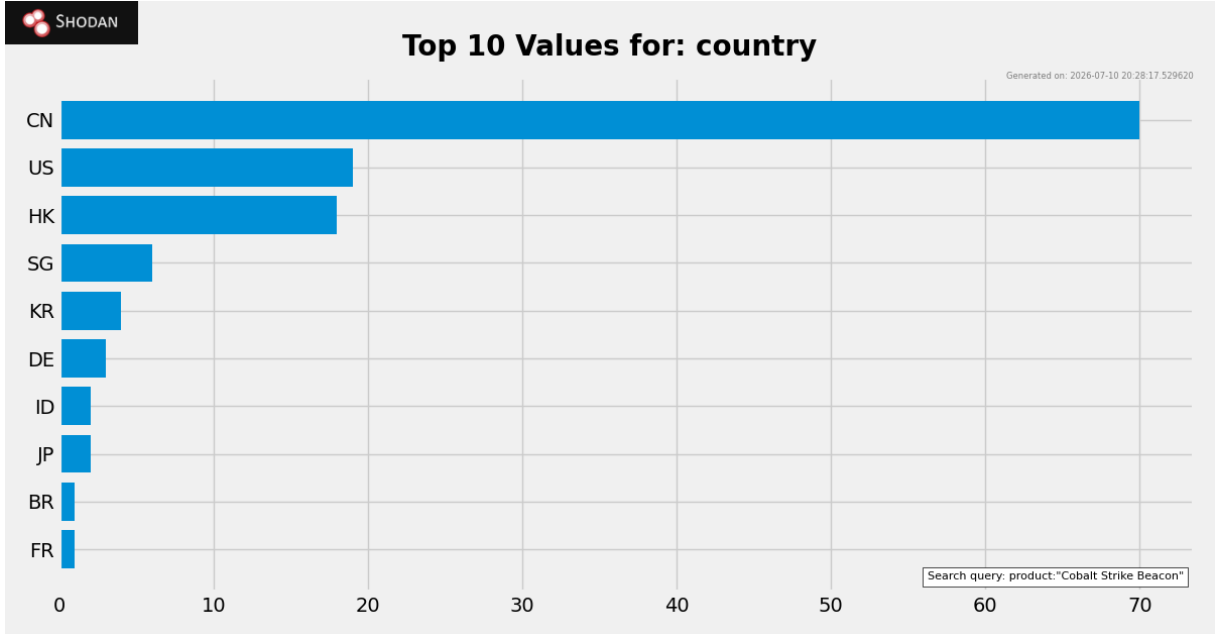
Shodan, Kasım 2021 itibarıyla taramalarında yakaladığı Cobalt Strike komuta kontrol sunucularını doğrudan dashboard paneline bir ürün olarak indekslemeye başlamıştır. Bu filtre, false positive oranı en düşük olan ve internet üzerindeki aktif altyapılara dair en hızlı, güncel ve toplu genel resmi sunan yöntemdir.

Shodan Sorgusu

product:"Cobalt Strike Beacon"



Görsel 1: İlgili Shodan Sorgusu



Görsel 2: Cobalt Strike Beacon Ürünlerinin Ülkelere Göre Dağılımı



TLS/SSL Sertifika Anomalilerini Yakalamak

C2 framework'leri (özellikle Cobalt Strike) ilk kurulduklarında kendileriyle birlikte varsayılan bir SSL/TLS sertifikası üretirler. Deneyimsiz veya aceleci bir saldırgan bu sertifikayı değiştirmedikçe, interneti tarayan Shodan gibi motorlara doğrudan kendilerini açık ederler.

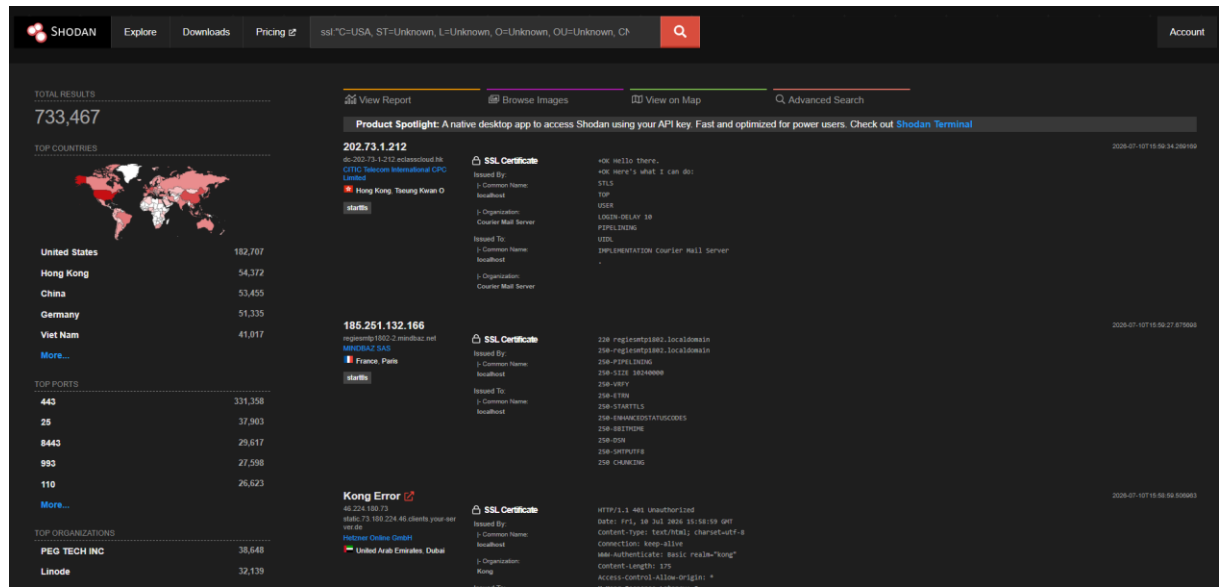
Cobalt Strike Varsayılan Sertifika Avı

Cobalt Strike'in eski ve bazı sızdırılmış sürümlerinde varsayılan sertifika bilgileri şu şekildedir.

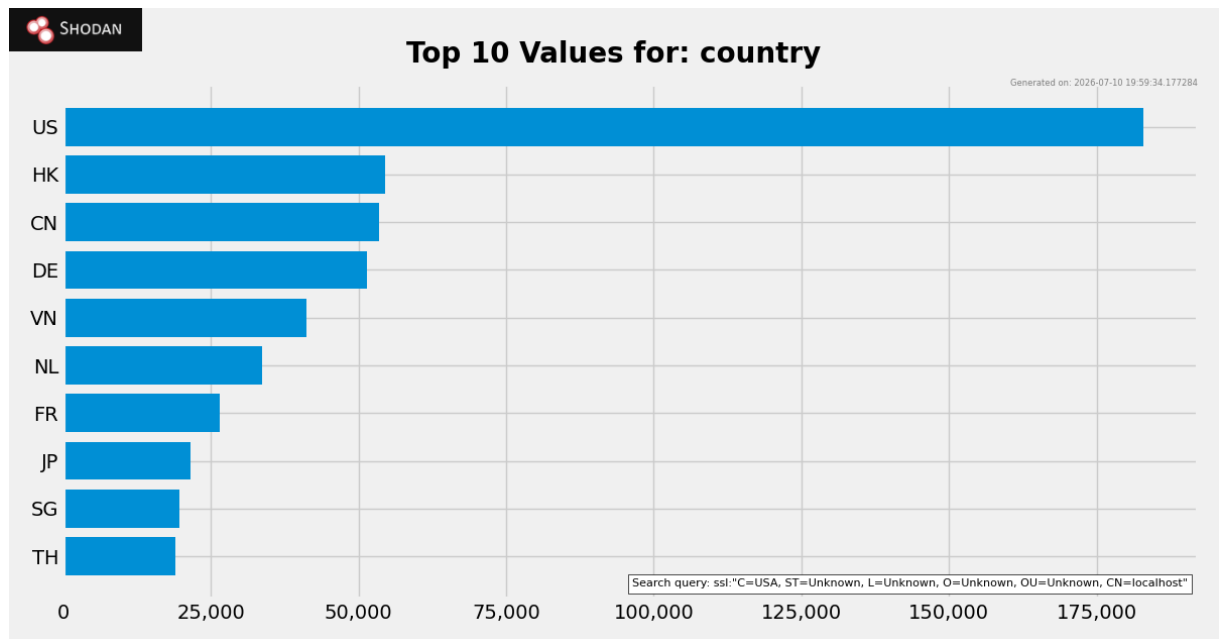
- Subject: C=USA, ST=Unknown, L=Unknown, O=Unknown, OU=Unknown, CN=localhost
- Issuer: C=USA, ST=Unknown, L=Unknown, O=Unknown, OU=Unknown, CN=localhost

Shodan Sorgusu:

ssl:"C=USA, ST=Unknown, L=Unknown, O=Unknown, OU=Unknown, CN=localhost"



Görsel 3: İlgili Shodan Sorgusu



Görsel 4: Cobalt Strike Varsayılan SSL Değerlerinin Ülkelere Göre Dağılımı

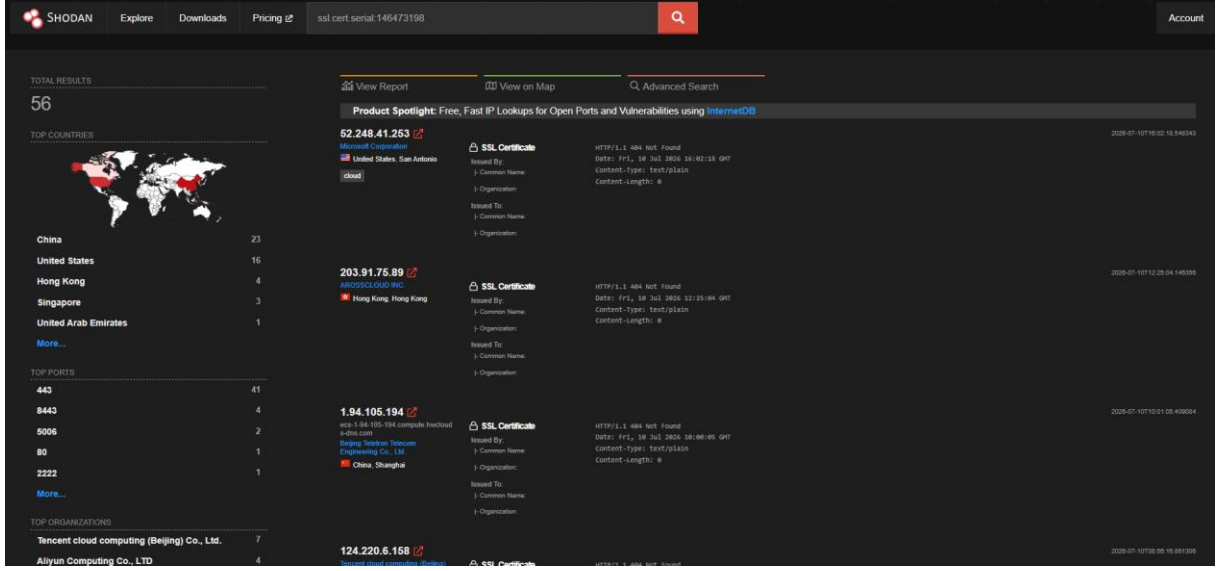


Güncel C2'lerde Seri Numarası Avı

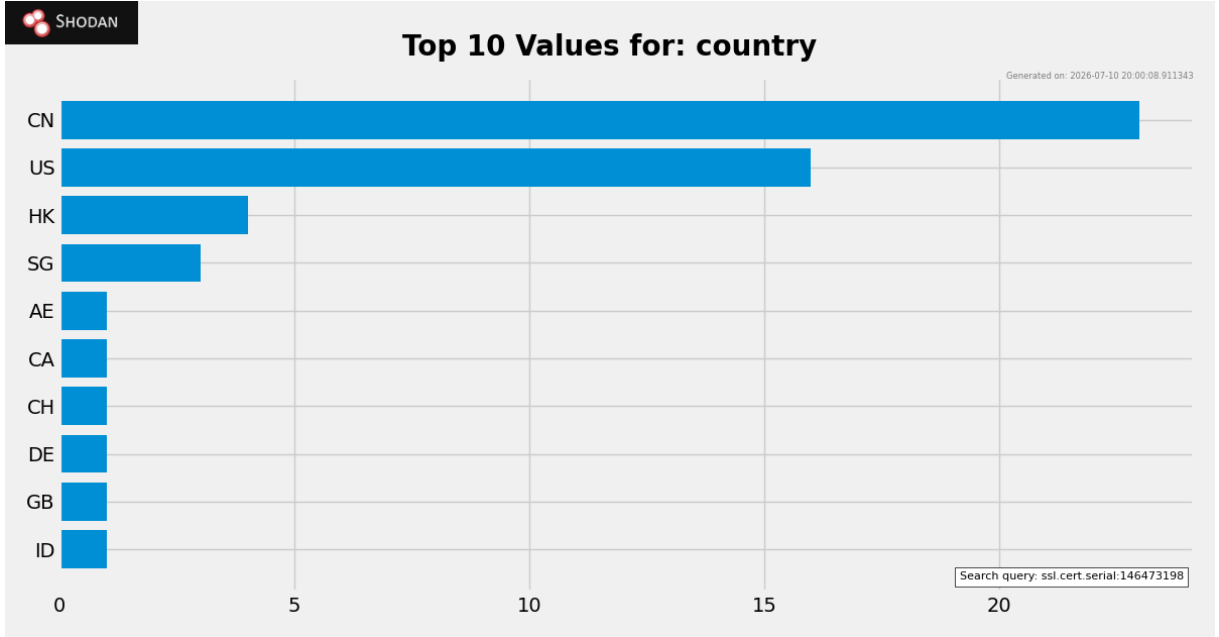
Saldırganlar sertifika içeriğini değiştirseler bile, bazı framework'lerin sertifika üretirken kullandığı sabit bir Serial Number veya ayırt edici bir parmak izi olabilir. Örneğin, Cobalt Strike'in belirli sürümlerinde varsayılan seri numarası 146473198 (Hex: 0x8bc922e) olarak üretilir.

Shodan Sorgusu:

ssl.cert.serial:146473198



Görsel 5: İlgili Shodan Sorgusu



Görsel 6: Güncel Cobalt Strike SSL Değerlerinin Ülkelere Göre Dağılımı



JARM Fingerprinting ile Avcılık

Saldırgan akıllıca davrandı, SSL sertifikasını tamamen meşru bir şirket gibi değiştirdi veya Let's Encrypt kullanarak geçerli bir sertifika aldı. Bu durumda ne yapacağız?

Bu durumda JARM devreye giriyor. Salesforce tarafından geliştirilen JARM, aktif bir TLS parmak izi alma aracıdır. Sunucunun sertifikasından bağımsız olarak işletim sisteminin, ham TCP kütüphanesinin ve SSL/TLS derleyicisinin paketlere verdiği yanıtları inceler. Sunucuya 10 farklı özel TLS Client Hello paketi gönderir ve gelen yanıtların şifreleme kombinasyonlarından 62 karakterlik benzersiz bir hash üretir.

Saldırgan sertifikayı ne kadar değiştirirse değiştirsın, arkada çalışan C2 sunucusunun (örneğin Java tabanlı bir Cobalt Strike Team Server veya Go tabanlı bir Sliver C2) TLS el sıkışma davranışı değişmez.

Popüler C2 Framework'lerin Bilinen JARM Hash Değerleri

C2 Framework	Tipik JARM Hash Değeri
Cobalt Strike (Java 11)	07d14d16d21d21d07c42d41d00041d24a458a375eef0c576d23a7bab9a9fb1
Sliver C2 (Golang)	2ad2ad0002ad2ad00041d2ad2ad41da5207249a18099be84ef3c8811adc883
Mythic	2ad2ad0002ad2ad00042d42d000000ad9bf51cc3f5a1e29eecd81d0c7b06eb

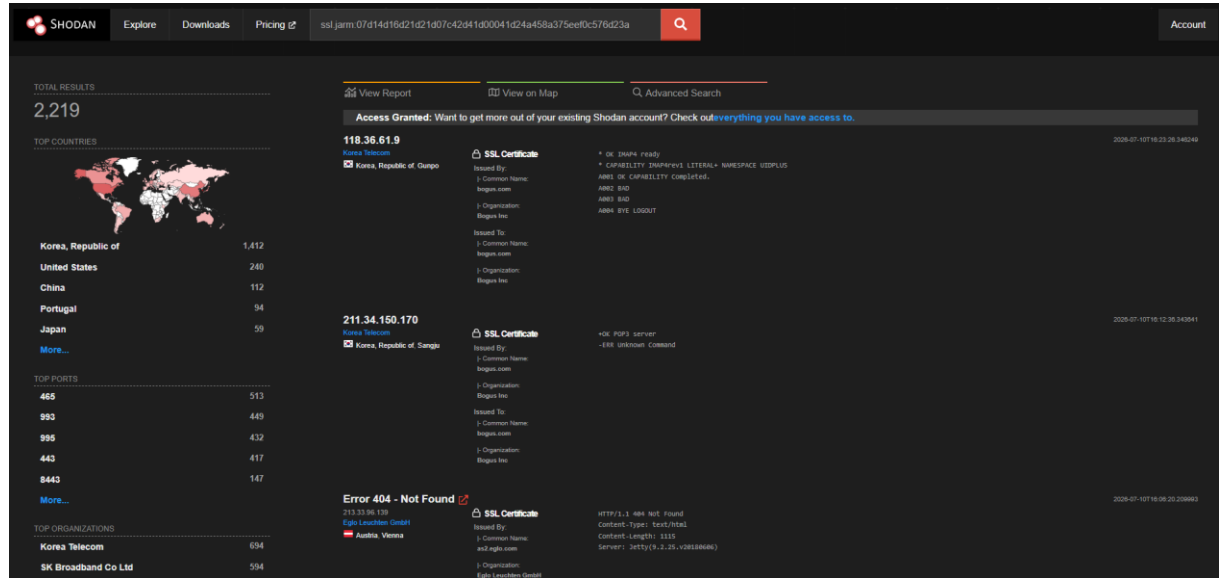
Tablo 1: Popüler C2 Framework'lerin Bilinen JARM Hash Değerleri

JARM ile Shodan Üzerinden Canlı Avcılık

Eğer internet üzerindeki aktif Cobalt Strike sunucularını JARM ile bulmak istiyorsak, Shodan'ın ssl.jarm filtresini kullanabiliriz.

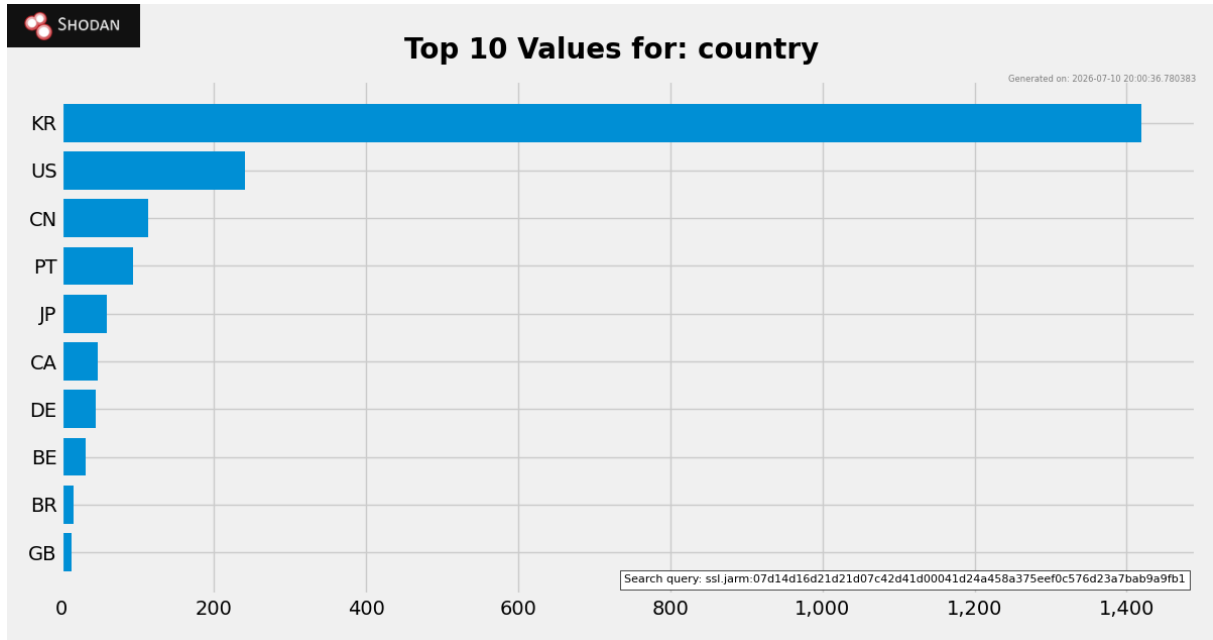
Shodan Sorgusu:

ssl.jarm:07d14d16d21d21d07c42d41d00041d24a458a375eef0c576d23a7bab9a9fb1



Görsel 7: İlgili Shodan Sorgusu

Not: Bu sorguyu çalıştırdığınızda karşınıza çıkan sunucuların büyük bir kısmı ya siber güvenlik firmalarının analiz sunucularıdır ya da aktif olarak operasyon yürüten tehdit aktörleridir.



Görsel 8: Cobalt Strike JARM Değerlerinin Ükelere Göre Dağılımı

HTTP Protokol ve Response Header Anomalileri

Her C2 framework'ü, kurban bilgisayarla haberleşirken belirli HTTP standartları kullanır. Bu standartlar bazen RFC dökümanlarına aykırı küçük anomaliler içerir.

Boşluk Anomalisi

Cobalt Strike sunucularının HTTP yanıtlarında uzun yıllar boyunca bilinen en ikonik hata, HTTP durum kodundaki fazladan boşluk karakteriydi.

- Standart bir web sunucusu şu yanıtı döner: "HTTP/1.1 200 OK" (OK sonrasında boşluk yoktur).
- Eski Cobalt Strike sunucuları ise şu yanıtı dönüyordu: "HTTP/1.1 200 OK " (OK sonrasında boşluk vardır).

```
00000000 48 54 54 50 2f 31 2e 31 20 32 30 30 20 4f 4b 20 HTTP/1.1 200 OK
00000010 0d 0a 43 6f 6e 74 65 6e 74 2d 54 79 70 65 3a 20 ..Content-Type:
00000020 61 70 70 6c 69 63 61 74 69 6f 6e 2f 6f 63 74 65 applicat ion/octe
00000030 74 2d 73 74 72 65 61 6d 0d 0a 44 61 74 65 3a 20 t-stream ..Date:
00000040 46 72 69 2c 20 38 20 4a 61 6e 20 32 30 31 36 20 Fri, 8 J an 2016
00000050 31 35 3a 31 37 3a 35 30 20 47 4d 54 0d 0a 43 6f 15:17:50 GMT..Co
00000060 6e 74 65 6e 74 2d 4c 65 6e 67 74 68 3a 20 30 0d ntent-Le ngth: 0.
00000070 0a 0d 0a ...
```

Extraneous whitespace after HTTP status code

Görsel 9: HTTP Yanıtındaki Boşluk Probleminin Hex Kodu

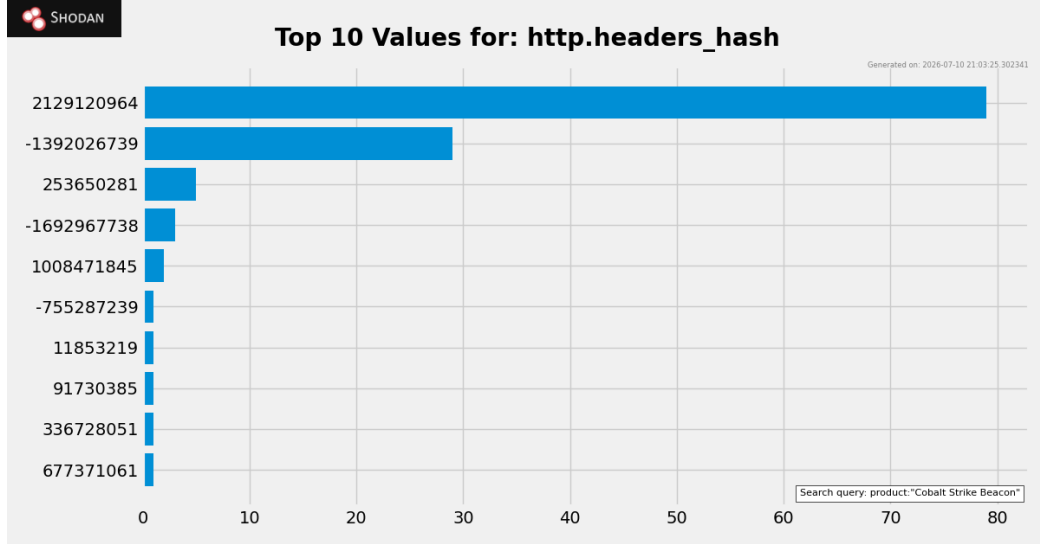
Bugün bu hata düzeltilmiş olsa da, benzer şekilde HTTP response başlıklarında yer alan "Content-Type", "Content-Length: 0" veya boş dönen "404 Not Found" sayfalarının HTML hash değerleri hala avlanabilir durumdadır.



Yanıt Başlığı Hash Analizi

Shodan, web sunucularının döndüğü HTTP yanıt başlıklarının dizilimini ve yapısal bütünlüğünü bütünsel olarak benzersiz bir sayısal imzaya dönüştürür ve bunu “http.headers_hash” filtresi altında indeksler. Bu yöntem, saldırganlar Server veya Content-Type gibi münferit alanları dinamik C2 profilleriyle değiştirirler bile, HTTP başlıklarının genel mimarisini değiştiremedikleri durumlarda gizli altyapıları yakalamak için bir iz sürme (pivoting) imkanı tanır.

Bilinen bir C2 sunucusundan elde edilen http.headers_hash:-1885449825 imzası Shodan'da tek başına aratıldığında, sistemin jenerik olarak etiketleyemediği ama tamamen aynı sunucu scriptleriyle ayağa kaldırılmış gizli ve yeni C2 sunucuları da deşifre edilerek engelleme listelerine dahil edilebilir.



GörSEL 9: Cobalt Strike Beacon Ürünlerinin HTTP Header Hash Dağılımı

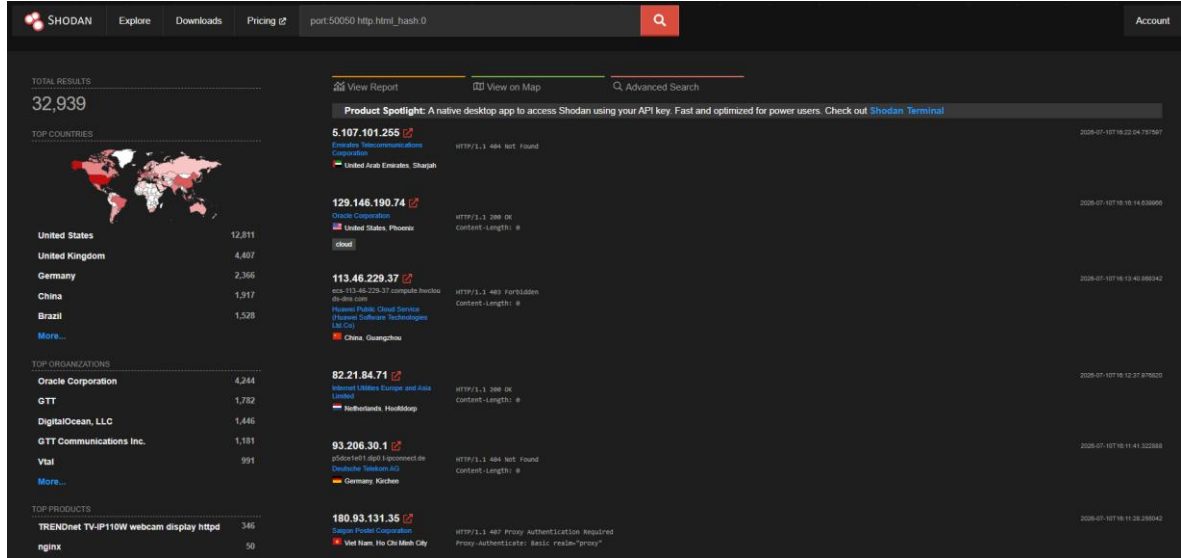


Boş 404 Sayfası ve Hash Avı

Çoğu C2 sunucusu, doğrudan web arayüzünden ziyaret edildiğinde şüphe çekmemek için boş bir "404 Not Found" sayfası gösterir. Shodan, sayfaların HTML içeriklerinin benzersiz hash'ini ("http.html_hash") çıkarır. Boş bir Cobalt Strike 404 sayfasının hash değeri genellikle "-1153130283" veya "0" olur.

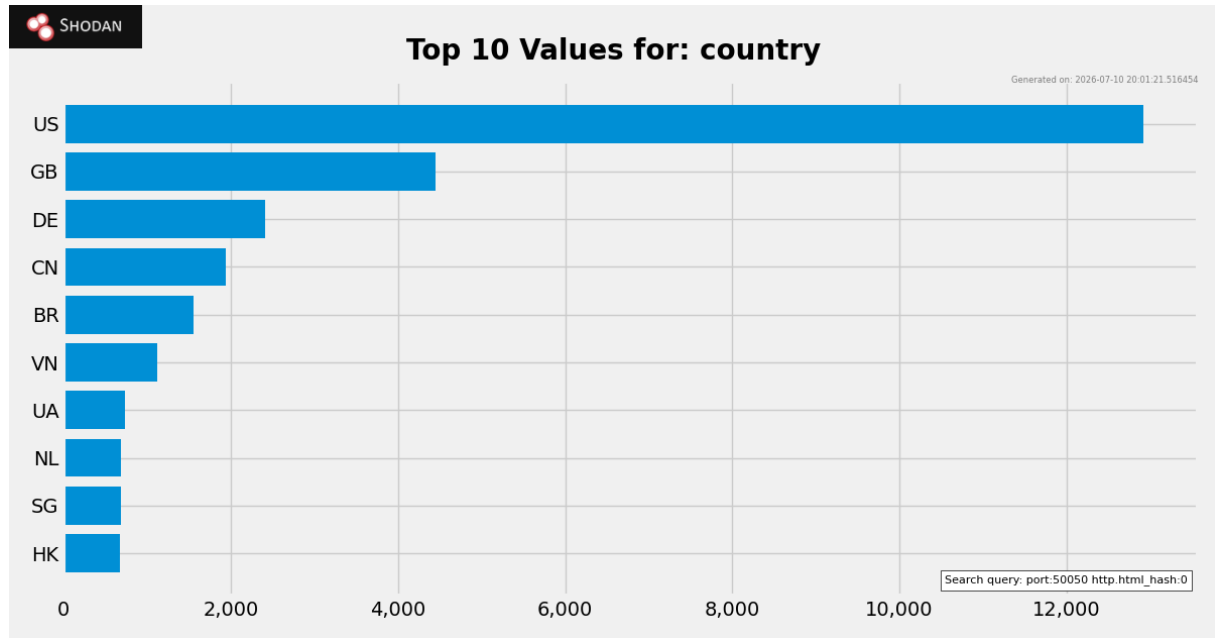
Shodan Sorgusu:

port:50050 http.html_hash:0



Görsel 10: İlgili Shodan Sorgusu

(50050 portu, Cobalt Strike'in varsayılan yönetim portudur).



Görsel 11: 50050 Portundaki HTML Hash Değeri 0 Olan IP Adreslerinin Ülke Bazlı Dağılımı



HTML Hash Analizi

Shodan tarayıcıları, ziyaret ettikleri web sunucularından dönen ham HTML kodlarının bütünsel yapısını inceleyerek kriptografik olmayan benzersiz bir sayısal imza üretir. Shodan veri tabanında “http.html_hash” filtresiyle tutulan bu değer, internet üzerindeki tamamen birbirinin kopyası olan (aynı kod mimarisine sahip) web sayfalarını bulmak ve kümelemek için kullanılır.

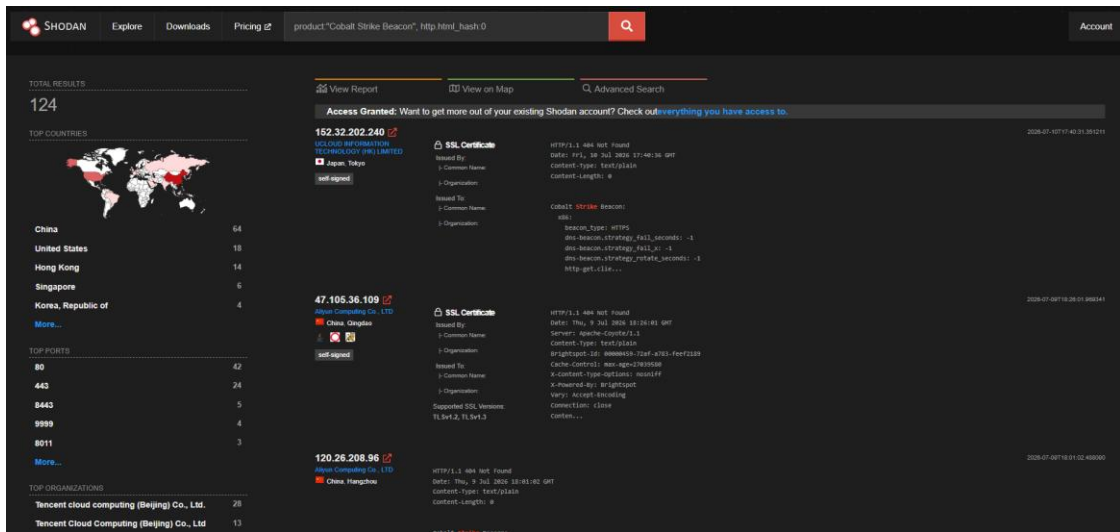
Cobalt Strike sunucuları fabrikasyon ayarlarında ve yetkisiz isteklerde bomboş bir sayfa döndüğünde, Shodan bu içeriğin hash karşılığını doğrudan 0 veya statik 404 sayfası için -1153130283 olarak indeksler. Ancak tehdit aktörü bu varsayılan konfigürasyonları değiştirip (örneğin sahte bir giriş sayfası, meşru bir şirket sitesi klonu veya özel bir hata şablonu yerleştirdiğinde) sunucuya kendine has bir HTML kodu yüklemiş olur.

Saldırganın özelleştirdiği bu yeni web içeriğinin benzersiz http.html_hash değeri saptandığında, Shodan üzerinde harika bir pivoting kapısı açılır. Örneğin; product:"Cobalt Strike Beacon" filtresiyle birleştirilmiş bir sorguda http.html_hash:-171462651 değeri aratıldığında tescilli az sayıda C2 sunucusu listelenebilir.

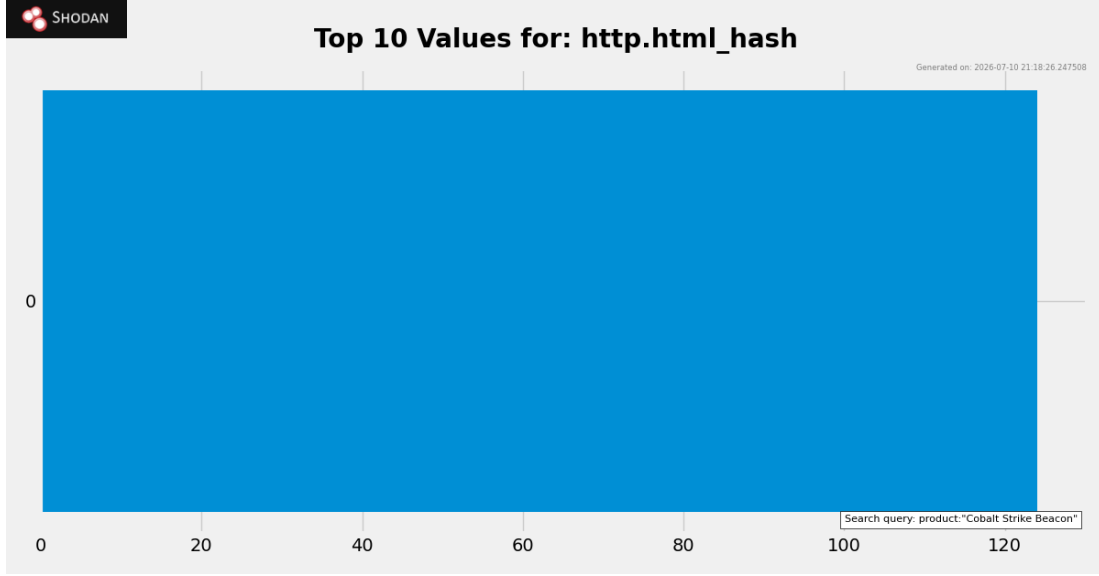
Analiz aşamasında product kısıtlaması sorgudan tamamen kaldırılıp sadece bu spesifik http.html_hash:-171462651 değeri aratıldığında, sonuç kümesi genişleyerek Shodan'ın jenerik olarak "Cobalt Strike" şeklinde etiketleyemediği ama tamamen aynı HTML şablonunu kullanan ve saldırganların gizlemeye çalıştığı diğer potansiyel zararlı IP adreslerini proaktif olarak deşifre etmemizi sağlar.

Shodan Sorgusu

product:"Cobalt Strike Beacon", http.html_hash:0



Görsel 12: İlgili Shodan Sorgusu



Görsel 13: Cobalt Strike Beacon Ürünlerinin HTML Hash Değerine Göre Dağılımı

JA3 ve JA3S Parmak İzi Entegrasyonu

JARM teknolojisi internete açık sunucuları proaktif olarak tarayarak parmak izi çıkarırken, ağ seviyesinde akan trafiği pasif olarak izlerken tehdit aktörlerini yakalamak için JA3 ve JA3S mekanizmaları kullanılır. Bu yöntem, özellikle şifrelenmiş trafik içerisindeki zararlı yazılım ajanlarını tespit etmek için çok etkilidir.

JA3 İstemci Parmak İzi

JA3, istemci ile sunucu arasındaki SSL/TLS el sıkışması sırasında istemcinin gönderdiği Client Hello paketini imzalamaya yarayan açık kaynaklı bir metottur. Bir JA3 imzası, TLS versiyonu, kabul edilen şifreleme algoritmaları (Cipher Suites), TLS uzantıları, desteklenen eliptik eğriler gibi alanların desimal değerlerinin toplanıp MD5 hash'ine dönüştürülmesiyle elde edilir.

Cobalt Strike'ın ağdaki ajanı olan Beacon, TLS haberleşmesini başlatmak için standart Windows soketlerini (WinINet/WinHTTP) kullanır. Bu durum her ne kadar sadece Cobalt Strike'a özgü olmasa da, kurumsal bir ağda meşru uygulamaların dışındaki şüpheli bir sürecin bu parmak izini üretmesi bir anomalidir.

Shodan mimarisi, doğası gereği dışarıdan içeriye doğru tarama yaptığı ve istemci gibi davranmadığı için, Shodan arama motoru üzerinden doğrudan pasif bir JA3 araması yapmak mümkün değildir.

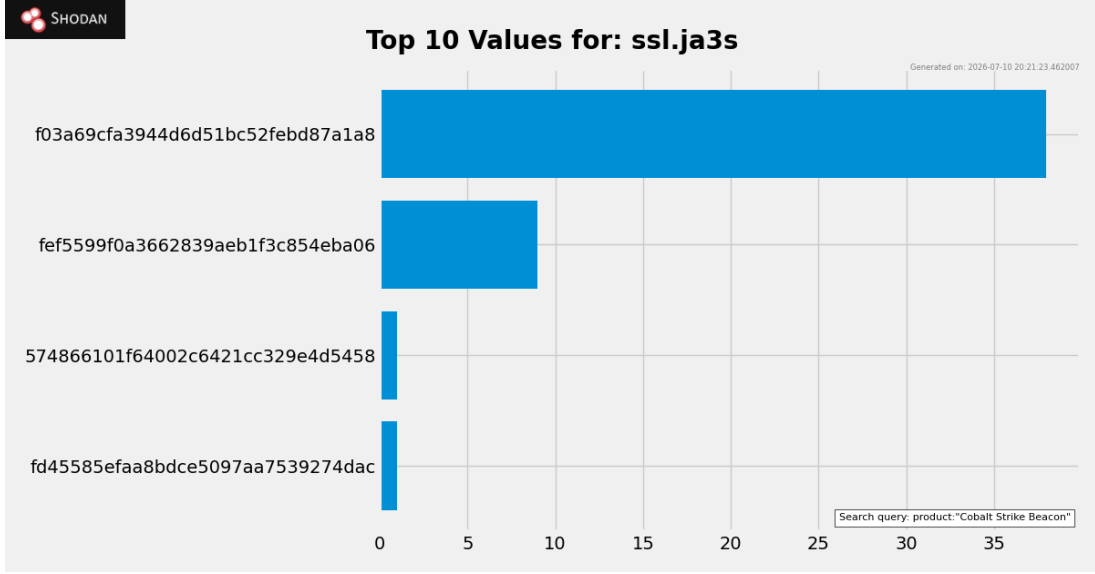
JA3S Sunucu Parmak İzi

İstemci parmak izinin (JA3) ardından, TLS el sıkışmasının sunucu tarafındaki anomalilerini yakalamak amacıyla JA3S metodu geliştirilmiştir. JA3S, C2 sunucusunun istemciye döndüğü Server Hello paketinin içerisindeki TLS Versiyonu, Kabul Edilen Şifreleme Algoritması (Accepted Cipher) ve Uzantı Listesi (List of Extensions) gibi alanların desimal değerlerini toplanıp MD5 hash'ine dönüştürür.



Tehdit Tespiti

Sadece tek bir JA3 veya JA3S değerine güvenerek engelleme kuralı yazmak, siber güvenlik operasyonlarında çok yüksek oranda False Positive üretme riski taşır. Çünkü meşru bir tarayıcı veya sistem bileşeni de aynı şifreleme kütüphanesini kullanıyor olabilir. Ancak gerçek bir tehdit avında, bilinen C2 sunucu listelerinden çıkarılan tüm JA3/JA3S kombinasyonları toplanarak bir veri kümesi oluşturulabilir. Ağ trafiğinde (PCAP analizi veya IDS kurallarında) belirli bir şüpheli JA3 istemci parmak izi ile buna karşılık C2 sunucusundan dönen spesifik JA3S parmak izi eşzamanlı olarak (korelasyon halinde) yakalandığında, saldırganın komuta kontrol trafiği çok yüksek bir doğruluk oranıyla deşifre edilmiş olur.



Görsel 14: Cobalt Strike Beacon Ürünlerinin ssl.ja3s Değerine Göre Dağılımı



ISP Odaklı Filtreleme

Saldırganlar C2 altyapılarını kurarken sadece yazılımsal konfigürasyonları varsayılanda bırakmakla kalmaz aynı zamanda operasyonel maliyetleri düşürmek veya kimlik gizlemek adına belirli internet servis sağlayıcılarını (ISP) ve veri merkezlerini toplu olarak tercih ederler. Saldırganların en sık kullandığı ve siber tehdit istihbaratı operasyonlarında şüpheli olarak işaretlenen sağlayıcıların başında ReliableSite.Net LLC organizasyonu gelmektedir.

Shodan Sorgusu

org:"ReliableSite.Net LLC" port:"443" HTTP/1.1 404 Not Found "Content-Length: 0"

IP Address	Domain	Details
104.243.44.36	reliable-site.net	HTTP/1.1 404 Not Found Date: Thu, 09 Jul 2020 22:42:09 GMT Content-Length: 0
104.194.9.68	reliable-site.net	HTTP/1.1 404 Not Found Server: nginx/1.25.4 Date: Thu, 09 Jul 2020 22:57:43 GMT Content-Length: 0 Connection: keep-alive X-Rate-Limit-Limit: 10 X-Rate-Limit-Remaining: 998888 X-Rate-Limit-Reset: 2020-07-09T22:59:01.042Z
104.243.46.194	reliable-site.net	HTTP/1.1 404 Not Found Content-Length: 0

Görsel 15: İlgili Shodan Sorgusu

org:"ReliableSite.Net LLC": Aramayı sadece bu veri merkezinin IP blokları ile sınırlandırarak tüm interneti taramanın getireceği gürültüyü engeller.

port:"443": Tehdit aktörlerinin kurban trafiklerini gizlemek amacıyla en çok tercih ettiği standart şifreli HTTPS portuna odaklanır.

HTTP/1.1 404 Not Found "Content-Length: 0": Cobalt Strike veya benzeri C2 framework'lerinin web arayüzünden doğrudan ziyaret edildiklerinde döndükleri fabrikasyon, tamamen boş gövdeye sahip yanıt anomalisiyle veri merkezini filtreler.



Watermark ID Analizi

Siber tehdit istihbaratı operasyonlarında ve sızıntı analizlerinde saldırganların kimliklerini veya ortak operasyonlarını saptayabilmek adına en kritik veri noktalarından biri Cobalt Strike beacon konfigürasyonlarında yer alan Watermark (Müşteri ID) parametresidir. Bu benzersiz sayısal değer, her bir Cobalt Strike satın alımında orijinal lisans dosyasına gömülen sabit bir kimlik numarasıdır.

Shodan, internet genelindeki taramalarında Cobalt Strike Team Server altyapılarının içindeki beacon konfigürasyon detaylarını da (cobalt_strike_beacon.x86 alanı altında) parse ederek indeksler. Tehdit avcıları, parmak izlerinden bağımsız olarak sadece bu Watermark değerini takip ederek dünya genelindeki farklı IP adreslerinin ve kampanyaların aynı aktöre ait olduğunu yüksek doğrulukla kanıtlayabilirler.

Sızdırılmış ve Korsan Sürümlerin Takibi

Siber suç dünyasında ve yeraltı forumlarında sızdırılan veya crack'lenen korsan Cobalt Strike sürümlerinde bu değer genellikle fabrikasyon olarak 0 veya 987654321 gibi jenerik sayılardan oluşur. Eğer bir sunucuda bu Watermark tespit edilirse, arkasındaki aktörün gelişmiş bir APT grubundan ziyade hazır crack'li araç kullanan fırsatçı siber suçlular (Ransomware iştirakleri, botnet operatörleri) olma ihtimali çok yüksektir.

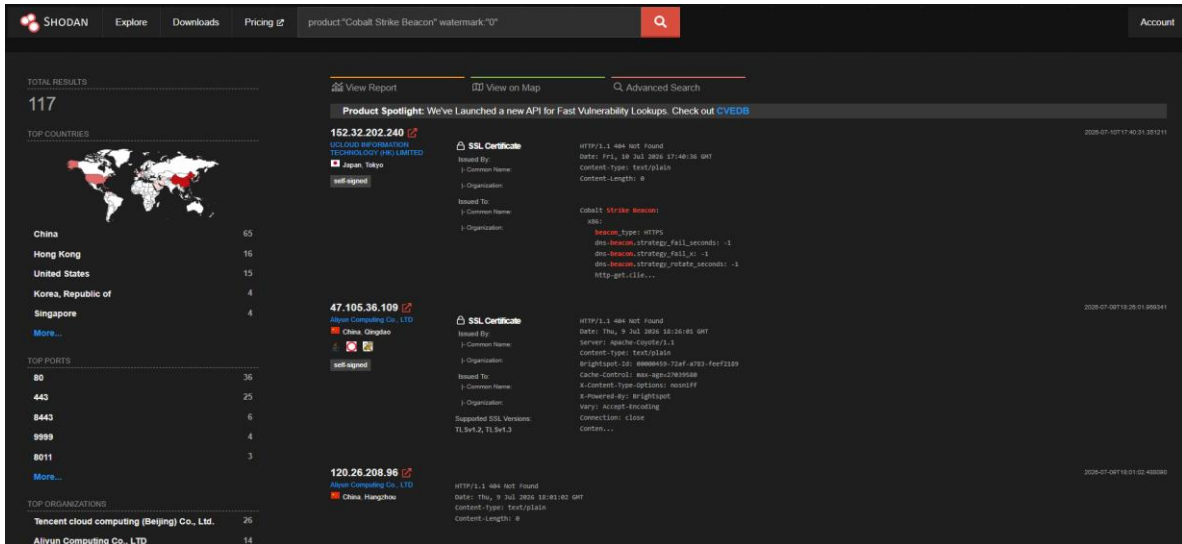
Aktör ve Kampanya Eşleştirmeleri

Geçmiş siber saldırılardan elde edilen tehdit istihbaratı verilerine göre, belirli spesifik Watermark değerleri doğrudan bilinen büyük siber suç örgütleriyle ilişkilendirilmiştir.

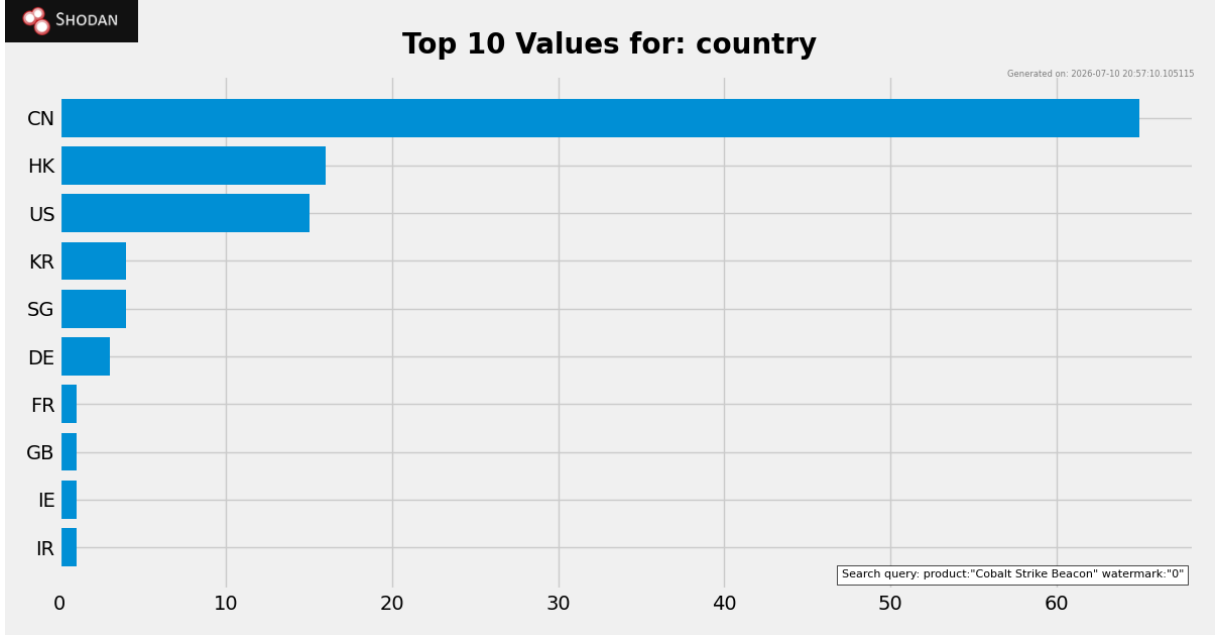
- **305419896:** Maze Ransomware fidye yazılımı grubuna bağlı iştiraklerin yürüttüğü operasyonlar altyapısı.
- **1359593325:** Trickbot zararlı yazılım ailesi ile ilişkili siber suç operasyonları.
- **1580103814:** Özellikle Conti sızıntılarında ve Ryuk dağıtımlarında sıkça rol oynayan BazarLoader kampanyaları.

Shodan Sorgusu

product:"Cobalt Strike Beacon" watermark:"0"



Görsel 16: İlgili Shodan Sorgusu



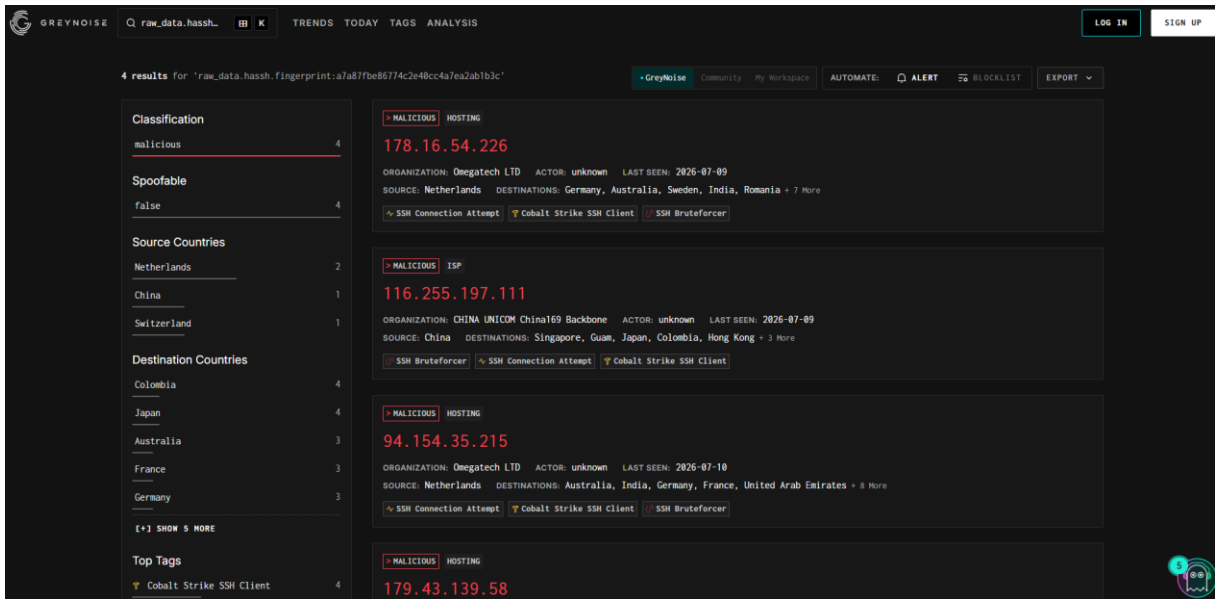
Görsel 17: Cobalt Strike Beacon Ürünlerinde watermark Değeri 0 Olan IP Adreslerinin Ülkelere Göre Dağılımı

Varsayılan SSH İstemci Parmak İzi Tespiti

C2 altyapılarının izini sürerken sadece TLS/SSL ve HTTP katmanlarına bağımlı kalmak analistler için eksik bir görünürlük yaratır. Tehdit aktörlerinin (özellikle Cobalt Strike operatörlerinin) Team Server altyapılarını yönetirken veya veri transferi yaparken kullandıkları SSH kütüphanelerinin el sıkışma parametrelerini imzalamak amacıyla HASSH profil tekniği kullanılır. Tıpkı şifreli web trafiğindeki JA3 gibi, SSH katmanındaki tünelleme anomalilerini yakalamak için bir pasif analiz yöntemidir.

Cobalt Strike altyapılarında, yönetim mekanizmalarının ve SSH istemcisinin (genellikle fabrikasyon olarak SSH-2.0-libssh2_1.8.0 veya SSH-2.0-libssh2_1.7.0 sürümleriyle) internete bıraktığı ham şifreleme metotlarının MD5 hash karşılığı şu şekildedir:

hassh: a7a87fbe86774c2e40cc4a7ea2ab1b3c



Görsel 18: İlgili GreyNoise Sorgusu



ASN ve Subnet Ölçeğinde Aktif Tarama Teknikleri

Tehdit aktörleri, operasyonları için C2 altyapılarını kurarken genellikle otomatize edilmiş scriptler kullanırlar. Bu durum, saldırganların sadece sunucu içi yazılımsal konfigürasyonları varsayılanda bırakmasına değil aynı zamanda birden fazla C2 sunucusunu aynı internet servis sağlayıcısının alt ağlarına veya komşu IP bloklarına toplu olarak yerleştirmelerine neden olur.

Pasif OSINT taramalarında şüpheli bir IP veya alt ağ saptandığında, bu blogun aktif olarak incelenmesi, aktörün henüz ifşa olmamış diğer "yedek" komuta kontrol sunucularını da gün yüzüne çıkarır.

Alt Ağ Analizi

Siber tehdit istihbaratı tarihindeki en net örneklerden biri Conti Ransomware grubuna aittir. Conti aktörlerinin 162.244.80.235 adresinde aktif bir Cobalt Strike C2 sunucusu konuşlandığı tespit edilmiş, analistler bu IP adresinin yer aldığı alt ağı mercek altına aldıklarında, tamamen aynı konfigürasyona ve imzalara sahip, Conti grubuna ait diğer gizli C2 sunucularını da deşifre etmeyi başarmışlardır.

Nmap Scriptleri ile Konfigürasyon Çekme

Şüpheli alt ağlarda tarama yaparken, hedef IP adreslerinin arkasındaki ham mimariyi deşifre etmek için Nmap Scripting Engine betiklerinden yararlanılır. Açık portlar üzerinden sunucuya istek gönderen özel NSE scriptleri (Örn: melting-cobalt projesindeki grab_beacon_config.nse betiği), C2 sunucusunun içindeki ham beacon konfigürasyon bloklarını (Watermark, Public Key, dinamik C2 parametreleri) doğrudan indirerek doğrulamamızı sağlar.

Bu yaklaşım, savunma ve SOC ekiplerinin sadece tek bir zararlı IP adresini engellemekle kalmayıp, saldırganın tüm operasyonel menzilini (IP aralığını) haritalandırarak kurumsal ağ genelinde tam kapsamlı bir defans hattı kurmasına imkan tanır.

Varsayılan DNS Sunucusu Yanıtı

Gelişmiş tehdit aktörleri, kurumsal ağlardaki sıkı takipleri aşabilmek ve HTTP/HTTPS tabanlı EDR/Web Proxy engellemelerini atlatabilmek adına komuta kontrol trafiğini tamamen DNS protokolü üzerinden tünellemektedir. Cobalt Strike mimarisi, bu operasyonlar için kendi üzerinde entegre bir DNS sunucusu barındırır.

Saldırganlar altyapılarını ayağa kaldırırken DNS konfigürasyonlarını özelleştirmeyi unuttuklarında, bu durum ağ katmanında tescilli bir anomaliye dönüşür.

Sahte IP Yanıt Anomalisi (Bogus IP Response)

Cobalt Strike Team Server üzerindeki DNS sunucusu aktif hale getirildiğinde, yetkisiz veya rastgele gelen herhangi bir DNS sorgusuna (A kaydı isteklerine) fabrikasyon olarak sabit ve sahte bir IP olan 0.0.0.0 yanıtını döner.

Ağ Seviyesinde Avcılık

Shodan, Censys gibi pasif OSINT platformları dışarıdan içeriye doğru ham DNS el sıkışmalarını doğrudan indeksleyemediği için bu anomali Shodan filtreleriyle internet ölçeğinde aratılamaz. Ancak kurumsal ağlarda, SIEM veya IDS/IPS sistemleri üzerinde iç ağdan dışarıya doğru giden DNS trafikleri izlenirken, meşru bir domain adresi olmamasına rağmen ısrarla 0.0.0.0 cevabı alan alt alan adı sorguları analiz edilerek aktif DNS Beacon operasyonları anında yakalanabilir.



Atlatma Taktikleri

Tehdit aktörleri bu anomalinin siber tehdit istihbaratı analistleri tarafından fark edilmesini engellemek adına Cobalt Strike'in dinamik C2 veya temel DNS ayarları içerisindeki `dns_stager_subhost` veya bogus IP parametrelerini değiştirerek sunucunun 0.0.0.0 yerine meşru bir bulut sağlayıcı IP'si dönmesini sağlayabilirler.

Avcılar İçin Kritik OpSec ve Güvenlik Uyarıları

C2 avcılığı yaparken gizliliğinizi korumak için şu kurallara kesinlikle uymalısınız:

- Doğrudan Tarama Yapmayın:** Shodan'da bulduğunuz bir IP adresine kendi kişisel bilgisayarınızdan veya kurumsal ağınızdan doğrudan "nmap" atmayın veya tarayıcı ile gitmeyin. Tehdit aktörü kendi sunucusunun loglarını izliyor olabilir ve sizin IP adresinizi saptayarak karşı saldırı veya yanıltma taktikleri uygulayabilir.
- False Positive Payı:** Unutmayın, bir JARM hash değeri sadece C2 sunucusuna ait olmayabilir. Meşru bir şirketin kullandığı nadir bir Java/Tomcat konfigürasyonu da aynı JARM hash'ini üretebilir. Bu yüzden tek bir bulguya dayanarak "Bu kesinlikle hacker sunucusudur" dememeli, sertifika ve port bilgilerini de doğrulamalısınız.
- Veriyi Zenginleştirin:** Bulduğunuz şüpheli IP adreslerini VirusTotal, AbuseIPDB veya GreyNoise gibi platformlarda sorgulatarak daha önce bildirilmiş bir zararlı faaliyeti olup olmadığını kontrol edin.



Kaynakça

<https://detect-respond.blogspot.com/2013/03/the-pyramid-of-pain.html>

<https://github.com/salesforce/jarm>

<https://blog.fox-it.com/2019/02/26/identifying-cobalt-strike-team-servers-in-the-wild/>

<https://hivesecurity.gitlab.io/blog/cobalt-strike-detection-hunting/>

<https://hunt.io/glossary/jarm-fingerprinting>

<https://www.shodan.io/search/facet?query=plex+200&facet=ssl.jarm>

<https://www.shodan.io/search/facet>

<https://www.redsiege.com/wp-content/uploads/2021/09/20210914-SIEGECAST-COBALT-STRIKE-BASICS.pdf>

<https://michaelkoczvara.medium.com/monitoring-threat-actors-c2-infrastructure-with-shodan-9be6f7aa1d41>

<https://forensicitguy.github.io/squeezing-cobalt-strike-intel-from-shodan/>

<https://medium.com/@bvebhav8/threat-hunting-c2-infrastructure-using-osint-f63089c79a14>

https://github.com/splunk/melting-cobalt/blob/main/grab_beacon_config.nse

<https://michaelkoczvara.medium.com/cobalt-strike-c2-hunting-with-shodan-c448d501a6e2>

YILDIZ

SİBER TEHDİT İSTİHBARATI TAKIMI

